ARNOBOT

# Inputdocument voor DPA (Data Processing Agreement)

Dit document verzamelt de feitelijke gegevens die een jurist of DPA-sjabloondienst nodig heeft om een verwerkersovereenkomst tussen ArnoBot (eenmanszaak van Anton Dirk Diepeveen) en een corporate klant op te stellen. Dit is geen juridisch document en mag niet als zodanig worden gebruikt of verstuurd.

## Partijen

- **Verwerkingsverantwoordelijke (customer)**: de corporate klant, namens wie ArnoBot persoonsgegevens van hun medewerkers verwerkt.
- **Verwerker (processor)**: Anton Dirk Diepeveen, handelend onder de naam ArnoBot (eenmanszaak, KvK 42184446), bezoekadres Verdunplein 17, 5627 SZ Eindhoven, Nederland. Contactpersoon: Arno Diepeveen. Privacycontact: privacy@arno.bot.

## Onderwerp en duur van de verwerking

Verwerking van persoonsgegevens van medewerkers van de klant ten behoeve van het leveren van de ArnoBot-coachingdienst, voor de duur van de overeenkomst tussen ArnoBot en de klant.

## Aard en doel van de verwerking

- Toegang verlenen tot ArnoBot (authenticatie, accountbeheer)
- Opslaan en tonen van coachingsgesprekken en profielgegevens van de gebruiker
- Genereren van persoonlijke AI-coaching
- Versturen van transactionele e-mails (welkom, trial, systeemmeldingen)
- Beveiliging van de dienst en foutopsporing
- Bij teamlicenties: geaggregeerde, niet-letterlijke groeirapportage aan de manager (nooit letterlijke gesprekscitaten of klantnamen)

## Categorieën betrokkenen

Medewerkers van de klant die een ArnoBot-account gebruiken (individuele bijdragers en, bij teamlicenties, hun manager).

# Categorieën persoonsgegevens

| Categorie | Toelichting |
|---|---|
| Accountgegevens | Naam en e-mailadres, afkomstig uit LinkedIn-profiel (of het bedrijfs-e-mailadres bij enterprise SSO) via Clerk |
| Profielgegevens | Salesrol, markt, uitdagingen en doelstellingen die de gebruiker zelf invult |
| Gesprekslogs | AI-coachingsgesprekken die de gebruiker voert met ArnoBot |
| Gedeelde gesprekken | Gesprekken die de gebruiker zelf deelt via een publieke link (optioneel, gebruikersinitiatief) |
| Technische gegevens | IP-adres en sessiedata, uitsluitend voor beveiliging en foutopsporing |
| Geüploade documenten | Bestanden die de gebruiker zelf toevoegt aan een gesprek; niet opgeslagen, alleen gebruikt om de vraag te beantwoorden en direct daarna weggegooid |

Geen bijzondere categorieën persoonsgegevens (AVG artikel 9) worden verwerkt.

# Sub-verwerkers

| Partij | Doel | Locatie / certificering | DPA |
|---|---|---|---|
| Supabase | Database, opslag gesprekken en profiel | EU, SOC 2 Type II | Aanwezig |
| Clerk | Authenticatie en gebruikersbeheer | SOC 2 Type II | clerk.com/legal/dpa |
| Vercel | Hosting en deployment | – | vercel.com/legal/dpa |
| Anthropic | AI-verwerking voor coaching (geen training op klantdata) | – | anthropic.com/legal/dpa |
| OpenAI | Spraakherkenning (Whisper) voor voice-invoer (geen training op klantdata) | – | openai.com/policies/dpa |
| Resend | Transactionele e-mails | – | resend.com/legal/dpa |
| Voyage AI | Embeddings en herrangschikking (kennisbank, sessiegeheugen) | SOC 2, HIPAA | Op aanvraag, geen publieke link |
| Sentry | Foutmonitoring en performance-tracing | – | sentry.io/legal/dpa |
| Upstash | Rate limiting (verwerkt IP-adressen) | – | Geen publieke DPA, op aanvraag |
| ElevenLabs | Tekst-naar-spraak voor ArnoBot Voice-abonnees (geen training op klantdata) | – | elevenlabs.io/dpa |
| PostHog | Bezoekers- en productgebruiksanalyse. Anoniem op publieke pagina's, pseudoniem (account-ID) in de ingelogde omgeving. Geen gespreks-, coaching- of analyse-inhoud. Session replay staat aan, beperkt tot 6 shell-pagina's, alle tekst en invoer gemaskeerd, bewaartermijn 30 dagen. | EU (Frankfurt) | Op aanvraag |
| Calendly | Boeken van een kennismakingsgesprek met Arno | – | calendly.com/legal/data-processing-addendum |

**Let op**: voor Voyage AI, Upstash en PostHog is er geen publiek self-service DPA-document gevonden. Vóór ondertekening met een corporate klant moet actief bij deze partijen een DPA worden opgevraagd, of moet worden bevestigd dat een DPA niet noodzakelijk is gezien de aard van de verwerking.

# Doorgifte buiten de EER

Een deel van de verwerking vindt plaats bij partijen gevestigd in de VS. Waarborg: Standard Contractual Clauses (SCC's) en sub-verwerkers met SOC 2 Type II-certificering.

# Beveiligingsmaatregelen

- Versleutelde verbindingen (HTTPS/TLS) voor al het datatransport
- Row Level Security (RLS) in de database: elke gebruiker heeft uitsluitend toegang tot eigen data
- Authenticatie via Clerk (SOC 2 Type II gecertificeerd), met optionele Enterprise SSO (SAML/OIDC) gekoppeld aan het bedrijfsdomein van de klant
- Bij teamlicenties: toegang alleen via uitnodiging van de manager, geen open zelfregistratie op het bedrijfsdomein
- Toegangscontrole via JWT-tokens en server-side API routes
- Geautomatiseerde monitoring voor foutdetectie (Sentry)
- Volledig beveiligingsdocument beschikbaar: arno.bot/arnobot-beveiliging.pdf

# Bewaartermijnen

| Categorie | Bewaartermijn |
|---|---|
| Persoonsgegevens en profiel | Zolang het account actief is. Verwijderd 30 dagen na beëindiging. Op verzoek binnen 10 werkdagen. |
| Gesprekslogs | Geanonimiseerd 30 dagen na beëindiging van het account |
| Technische logs | Maximaal 90 dagen |
| Geüploade documenten | Niet opgeslagen |

# Meldplicht datalekken

Betrokkene/klant wordt zo spoedig mogelijk geïnformeerd, uiterlijk binnen 72 uur na ontdekking.

# Rechten van betrokkenen

Inzage, rectificatie, verwijdering en overdraagbaarheid. Gebruikers kunnen dit deels zelf via hun account (data downloaden, account verwijderen, profiel aanpassen). Overige verzoeken via privacy@arno.bot, beantwoord binnen 10 werkdagen.

# Openstaand vóór ondertekening

- DPA opvragen bij Voyage AI, Upstash en PostHog, of expliciet motiveren waarom niet nodig. Voor PostHog is dit urgenter geworden sinds de uitbreiding naar pseudonieme productanalyse van ingelogde gebruikers (2026-08-30): bij aanvraag ook de sub-verwerkersketen bevestigen (o.a. AWS eu-central-1).

- SOC 2 Type II / ISO 27001-status van ArnoBot zelf: nog niet aanwezig, indien de klant dit als harde eis stelt is dit een apart traject